Setnayan — Records of Processing Activities (RoPA) / Data Inventory

> **DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted. · 2026-07-05**

> **Revised 2026-10-22** — measured against the shipped code on `origin/main` (`aceb080a0a`), not against older documents. What changed in this revision (full list: `00_WHAT_CHANGED_2026-10-22.md`):
> - **DPS-02** re-stated: the government ID, live selfie / liveness video and AMLC screening were **retired 2026-07-03**; Persona / Veriff / Onfido / ComplyAdvantage / AMLC are **not** recipients (finding #8/#9 of `NPC_Pack_Findings_VERIFIED_2026-08-24.md`, applied here for the first time).
> - **DPS-09** re-stated: **PostHog was removed** (PR #6774, merged 2026-10-22). There is no product-analytics processor.
> - **DPS-11** re-stated: **essential first-party cookies only, no cookie banner** (`/cookies`, effective 2026-10-22).
> - **New rows DPS-21 → DPS-28:** first-party site Visits (daily aggregates, daily-salted hash) · sign-in with Google and Apple · Apple in-app purchase (built, switched off) · the supplier Papic capture lane and supplier photo takedown · text checks sent to OpenAI and LanguageTool · error monitoring (Sentry) · connected accounts (YouTube, Drive, TikTok, Instagram, Gemini) · Pabuya gift records.
> - **DPS-03/04/08/10/14** updated: guests get no e-mail (2026-09-29); the face selfie is erased 12 hours after the event; receipt screenshots are read by Anthropic; payment records 10 years; the withdrawn "5 years post-event" window struck where it lingered.
> - **Shared-infrastructure table** brought in line with the processors the code actually calls (§ 0).
> - **Account deletion** re-stated in DPS-01: request → admin review → anonymise-and-retain (finding #6/#16), not "30-day grace then purge".
> - The face-data (3-month) and supplier-upload (90-day) deletion sweeps **now exist in code** (PR #4735, merged 2026-08-23); DPS-02 and DPS-04 say so.

The accountability record RA 10173 (Data Privacy Act of 2012) and its IRR require a Personal Information Controller (PIC) to maintain: a register of the Data Processing Systems (DPS) it operates. Each row below is **one DPS**. Sourced from `01_Contracts/Setnayan_Privacy_and_Security_Policy.md` (§1 data collected, §3 where data lives, §4 retention, §6 consent, §10 sub-processors) and `03_Strategy/Compliance_Pack_PersonGraph_DRAFT_2026-07-05.md`. Facts not established in those sources are marked `[TO CONFIRM]` — none invented.

---

0. Controller & governance identification

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II
DTI Business Name Registration	BN 8297508 · valid 25 Jun 2026 – 25 Jun 2031
Brand / trade name	Setnayan
Public domains	setnayan.com ((!) CORRECTED 2026-10-22 — `setnayan.ph` struck: not owned)
Registered business address	76 Sampaguita Avenue, Quezon City — barangay + ZIP `[OWNER TO SUPPLY]`

Total headcount / employees	2 (owner + VP), both with personal-data access
NPC registration number (if already registered)	`[TO CONFIRM]`
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · **dpo@setnayan.com** (published contact, owner ruling 2026-09-22) · registered on the NPC DPO system 2026-07-07
DPO response SLA	15 business days (non-urgent); immediate for breach notifications
Breach notification	NPC + affected users within 72 hours of confirmation (policy §8)
Estimated data-subject counts (customers / vendors / guests)	Last measured 2026-08-17: 9 accounts · 39 guests · 2 shops · 6 events · 0 active face vectors. **Not re-measured 2026-10-22 (no production access from this session)** — read live from `/admin/compliance/data-sheet` on filing day

Shared infrastructure (applies across DPS's unless a row narrows it)

> **Rebuilt 2026-10-22 from the hosts the shipped code calls** (`origin/main` `aceb080a0a`). Rows that only run when a key or a switch is set say so; production key/switch values were not readable from this session. Full per-processor table: Privacy Manual § 8.2.

Layer	Provider	Location	Role
Web / application hosting	Vercel	US company; functions pinned to **Singapore** (`vercel.json` `sin1`)	Processor — every request in transit
Primary database (PII + transactional **+ biometric face vectors**)	Supabase / Postgres	**Singapore**	Processor · AES-256 at rest · RLS. **Face vectors live HERE** (`guest_face_enrollments.face_vecto` `user_face_profiles`)
Media (photos / video / enrolment selfies / payment proofs / supplier documents / chat files)	Cloudflare R2	**Asia-Pacific (APAC)** [OK] *confirmed in the Cloudflare dashboard 2026-08-01*	Processor · private buckets, short-lived signed URLs. **Does NOT hold face vectors**
Live-video relay · bot check · STUN	Cloudflare (TURN, Turnstile, STUN) · Google STUN	Global network	Processor — IP + media in transit only; TURN/Turnstile only when keys are set
Transactional email	Resend	United States	Processor. (!) Since 2026-09-29 **guests receive no e-mail** (owner ruling); couples, hosts and suppliers do
Error monitoring	Sentry	United States	Processor — stack traces + masked replay on error; e-mail/phone/face-vector scrubbing

AI assistance	Anthropic	**US**	Processor — receipt reading, supplier Deep Search, mood-board screening, theme sentence, category requests (when the key is set)
Text moderation / grammar	OpenAI (moderation) · LanguageTool (public API, Germany)	US · EU	Processor — couple editorial and guest-column text
Connected accounts	Google (sign-in, YouTube, Drive, Gemini) · Apple (sign-in, in-app purchase) · Meta · TikTok	US / SG	Processor or independent controller per connection — only after the user connects or the switch is on
Maps / embeds	OpenStreetMap Nominatim + tiles · Vimeo oEmbed	UK · US	Address text / link only
Web push	Browser push services (Apple / Google / Mozilla)	Browser vendor	Notification content, when push keys are set
~~Vendor ID verification~~	~~Persona / Veriff / Onfido~~	—	[X] **Struck 2026-10-22 — retired 2026-07-03, never engaged**
~~Product analytics~~	~~PostHog~~	—	[X] **Removed 2026-10-22 (PR #6774)**
Music generation	Suno	—	**Not called by the code**; no personal data — not a processor

Cross-border baseline: routine operation crosses the SG↔PH border, and several processors are in the US or EU; encrypted in transit (TLS 1.3), subject to NPC oversight (policy §10). (!) CORRECTED 2026-10-22: **no DPA or SCC is signed with any processor yet** (`dpa_on_file: false` on every row of `apps/web/lib/subprocessors.ts`; NPC task `t2-8`). The earlier wording asserted signed DPAs.

---

1. Records of Processing Activities — one record per Data Processing System

Legend — Legal basis per RA 10173 §12 (personal info) / §13 (sensitive personal info): **Contract** = §12(b) performance of contract; **Consent** = §12(a)/§13(a); **Legitimate interest** = §12(f); **Legal obligation** = §12(c)/§13(b)/§13(f). SPI = Sensitive Personal Information per RA 10173 §3(l).

DPS-01 · Customer / Couple Account & Event Planning

Field	Detail
Purpose	Provide the contracted planning platform: account, event setup, vendor matching (Guided + DIY), seating, save-the-date, in-app services
Legal basis	Contract (§12(b)) — service delivery; Consent (§12(a)) for marketing-sample opt-in (policy §6.2)

Data subjects	Customers (couples / organizers)
Personal data categories	Full name, mobile, email, optional profile photo; event data (date, venue, target pax, role); behavioral/in-app activity, Guided-mode decisions, search queries; uploaded content (Save-the-Date photos, invitation customizations)
SPI?	**N** (no SPI in the core account record)
Recipients / sub-processors	Supabase (DB), Vercel (hosting), Cloudflare R2 (content); Setnayan Team on mediation only
Cross-border transfer	SG (Supabase); APAC (R2)
Retention	Account profile: kept while the account is open. **On deletion: the user files a request (type DELETE on Profile) → an admin reviews it within 24 hours (active events, bookings, balance) → approval runs the erasure at once, which BLANKS the personal fields and keeps the anonymised business records** (`eraseUserAccount`, anonymise-and-retain; tax/receipt records kept for their legal period). (!) CORRECTED 2026-10-22 — this read "active + 30-day grace on deletion, then purge"; no grace period and no scheduled purge exist in code (findings #6/#16 of 2026-08-24, migration `20261106000000_account_deletion_requests.sql`). Event data: **Kept for the LIFE OF THE ACCOUNT**, deleted when the couple closes or deletes their account. Owner ruling 2026-08-17. ((!) CORRECTED 2026-10-22: "plus the existing 30-day tail" struck — no tail exists in code.) (!) **CORRECTED — the previous "5 years post-event, auto-purge at T+5y" rule is WITHDRAWN, not merely unbuilt.** Building it as written would have DELETED THE PHOTOS: in the live schema the photo rows, the guest list, the tags, the schedule and the supplier list all cascade from the event, so removing a wedding removes its album — contradicting the owner's twice-locked rule that no photo is ever deleted, only compressed. Retention is therefore bound to the purpose that is still running (the couple's own album and its context) rather than to a timer, matching the treatment of account data. Any future end date must be built to remove planning details WITHOUT touching the photos.
Security measures	AES-256 at rest; RLS per-user isolation; TLS 1.3; bcrypt passwords; optional 2FA; signed URLs for media
Risk level	**Medium**

DPS-02 · Vendor Account, Profile & Verification

Field	Detail
Purpose	Vendor (supplier) onboarding, business profile, and the business verification checklist

Legal basis	Contract (§12(b)); Legitimate interest (§12(f)) — business-document review, portfolio check, reference calls; Consent captured at registration. (!) **CORRECTED 2026-10-22 — the AMLC sanctions/PEP basis is struck: no screening is performed (retired 2026-07-03).**
Data subjects	Vendors (business owners / primary representatives)
Personal data categories	The **eight** live checklist slots (`DOC_SLOTS`, `apps/web/lib/vendor-verification.ts`): DTI certificate · BIR Form 2303 · Mayor's Permit · bank-account proof · portfolio samples · client references · social media links · a 15-minute Google Meet (identity confirmation). Plus the service profile; financial (bank/e-wallet payout account, transaction history); behavioral (response times, conversion). (!) **CORRECTED 2026-10-22: the government ID, live selfie, liveness video, phone/email OTP and AMLC screening slots were retired 2026-07-03 and are no longer collected** (code comment above `DOC_SLOTS`: *"government_id, live_selfie, phone_email_otp, and amlc_screening are RETIRED"*).
SPI?	**Y — re-based.** The **BIR Form 2303 carries the Tax Identification Number**, a government-issued identifier (RA 10173 §3(l)). (!) CORRECTED 2026-10-22: the classification previously rested on a government ID and a liveness video, which are no longer collected; the classification is kept, its basis changed (owner, 2026-08-24). Legacy uploads made before 2026-07-03 may still exist in storage and are governed by the retention line below.
Recipients / sub-processors	Supabase (Postgres, Singapore); Cloudflare R2 (APAC) private verification bucket, admin-only access; Google (the Meet call itself, run on the vendor's and our own Google accounts). (!) **CORRECTED 2026-10-22 — Persona / Veriff / Onfido and AMLC API / ComplyAdvantage were never engaged and are NOT recipients** (retired 2026-07-03; no relationship exists and no personal data has flowed). The "DTI Database" is **not a data feed**: the code makes no call to DTI (the only DTI address in the code is a help link to the public BNRS site), so any check is a manual look-up by an admin.
Cross-border transfer	SG (Supabase); APAC (R2). (!) Previously declared US/UK/PH transfers to identity and screening providers are retired — none occur.

Retention	Raw uploads (and any legacy government ID / selfie / liveness video from before 2026-07-03, bank micro-deposit, portfolio): **deleted 90 DAYS AFTER the approve/reject decision** — owner ruling 2026-08-17. The DECISION RECORD ONLY (outcome, deciding admin, timestamp) is retained **7 years** (BIR §235). DTI / BIR 2303 / Mayor's Permit: 7 years. Transaction history: 5 years (policy §4). (!) **UPDATED 2026-10-22 — the qualifier this row carried from 2026-08-17 ("ENFORCEMENT NOT YET BUILT") is no longer true:** the 90-day supplier-upload sweep shipped in PR #4735 (merged 2026-08-23, *"Delete what we said we would delete"*). Whether it has run against production data cannot be read from a session without production access. (!) **CORRECTED 2026-08-17 (same day):** an earlier revision of this row said *"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"* — **that was wrong.** Setnayan deliberately runs **cron-free**: a database compare-and-swap claim fired from request traffic drives **~16 periodic jobs**, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that **no job covers THIS class yet** — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one.
Security measures	Extra-restricted R2 bucket (single admin role); no third-party verification call; AES-256; RLS; audit log on all admin decisions
Risk level	**Medium–High** (SPI: the TIN on BIR Form 2303; legacy pre-2026-07-03 ID uploads until the 90-day sweep removes them). (!) CORRECTED 2026-10-22 — was "High (SPI: gov ID + biometric liveness)", which described the retired collection

DPS-03 · Guest List & RSVP

Field	Detail
Purpose	Manage the couple's guest list, RSVP status, roles, table assignment, and special requests
Legal basis	Contract (§12(b)) — organizer's event service; Consent (§12(a)) for guest-provided data / photo consent at RSVP (policy §6.1)
Data subjects	Guests
Personal data categories	Full name, mobile, email, optional profile photo; event linkage + role (principal/secondary sponsor, family, friend), RSVP status, table assignment; behavioral (reels built, re-shares)
SPI?	**Y (health / religion, possible)** — `guests.dietary_restrictions` + `meal_preference` are confirmed in the live schema and `/privacy` labels them sensitive. A wedding guest list also reveals family relationships. [OK] `[TO CONFIRM]` resolved 2026-10-22

Recipients / sub-processors	Supabase; event organizer (couple); coordinator within join-permission scope; browser push services for a guest who allows notifications. Plain guests' names are visible only to recognised guests and hosts, never the public (`/[slug]/everyone` is `noindex`). (!) UPDATED 2026-10-22: **guests receive no e-mail** (owner 2026-09-29, *"No email. Either use the qr and link only"*; extended 2026-10-02 to the Save-the-Date fan-out) — the RSVP no longer asks for one
Cross-border transfer	SG (Supabase)
Retention	Follows the parent event — kept for the life of the couple's account (DPS-01); a removed guest is soft-deleted (`deleted_at`). (!) CORRECTED 2026-10-22 — this read "5 years post-event", the window WITHDRAWN on 2026-08-17. QR-scan records keep the IP truncated, and a guest may switch their own scan record off (`guests.scan_tracking_opt_out`, 2026-09-02)
Security measures	RLS event-scoping; TLS 1.3; guest opt-out toggles; AES-256
Risk level	**Medium** (High if dietary/health SPI confirmed)

DPS-04 · Face Vectors / Auto-Tagging (per-event, consented)

Field	Detail
Purpose	Auto-tag guests in an event's photo gallery via face matching (couple-scoped only)
Legal basis	Consent (§13(a)) — guest opts in by uploading RSVP profile photo for this purpose; revocable via "Delete my face data" / Photo Consent toggle (policy §6.1)
Data subjects	Guests
Personal data categories	128-dimension **face vectors** computed **in the guest's browser** from a selfie the guest takes after ticking a separate, default-off consent box; the selfie itself (R2); consent timestamp, source and copy version. **Adults 18+ only** — enrolment refuses a guest the host has marked as a minor (`app/papic/face-enroll-actions.ts`). One end-of-event rescan runs the same open model inside our own server function and stores no face of anyone not enrolled. (!) Corrected 2026-10-22 — "derived from RSVP photo + check-in kiosk" described the old design
SPI?	**Y — BIOMETRIC** data (RA 10173 §3(l)). Highest-sensitivity category in the platform

Recipients / sub-processors	**Supabase (Singapore) — the vectors themselves**, as JSONB in `guest_face_enrollments.face_vector` + `user_face_profiles`; Cloudflare R2 (APAC) holds only the **source selfie image** (`asset_url`). [OK] **`[TO CONFIRM]` RESOLVED 2026-07-31 from shipped code: there is NO third-party matching engine.** Embedding runs **on-device / in-browser** (face-api.js / MediaPipe, `lib/face-embed.ts`) and matching runs against our own Postgres rows — **no face data is sent to any AI sub-processor.** *(Prior text placed a "per-event encrypted vector index" on R2; no such index was ever built.)*
Cross-border transfer	**Singapore** (Supabase — the vectors) + **APAC** (R2 — the source selfie images). Corrected 2026-07-31; both outside PH, so the § cross-border conclusion is unchanged, but the *location of the biometric SPI* is now stated accurately.
Retention	[OK] **UPDATED 2026-10-22.** The selfie, the enrolment row and its vector are **erased when the event's Papic closes, 12 hours after the event ends** (owner 2026-09-30, *"face will be only saved for that day"*; job `face-selfie-papic-close`, PR #6195). Backstop: **deleted 3 MONTHS AFTER THE EVENT ENDS** (92 days; job `face-data-retention`, PR #4735 merged 2026-08-23). Earlier deletion any time by withdrawing consent. (!) The qualifier this row carried from 2026-08-17 ("ENFORCEMENT NOT YET BUILT") is **no longer true** — both sweeps exist in code; they run on request traffic (cron-free), so their timing depends on traffic; that they have run in production was not verified from this session. (!) The live `/privacy` table states only the 3-month rule — the 12-hour erase is not yet on the page (open copy item). Owner ruling 2026-08-17 (history): (!) **CORRECTED 2026-08-17 (same day):** an earlier revision of this row said *"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"* — **that was wrong.** Setnayan deliberately runs **cron-free**: a database compare-and-swap claim fired from request traffic drives **~16 periodic jobs**, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that **no job covers THIS class yet** — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one. **Deleting face data does NOT remove photo tags** — verified in the live schema: a tag carries the guest link itself and has no reference to face data, so nothing cascades. Guests keep every photo already delivered; only FUTURE automatic matching is lost, which is why the 3-month mark is safe. (!) CORRECTED 2026-08-17 — this row previously declared a "per-event lifetime + 5 years, auto-purge with event data" rule, which nothing implemented — and which had silently become "never deleted" when the media row moved to indefinite retention on 2026-08-02.
Security measures	**Per-event scoped — vectors never reused across events**; encrypted at rest; no cross-event face recognition (design lock, Person Graph DPIA #6); confidence-gated auto-tag
Risk level	**High** (biometric SPI)

DPS-05 · Papic / Photo & Video Capture & Delivery

Field	Detail
Purpose	Capture, store, tag, and deliver event photos/clips to couples and guests; Personal Reel rendering
Legal basis	Contract (§12(b)) — paid capture/delivery service; Consent (§6.1) for likeness/photo participation; opt-out → face-blur
Data subjects	Guests, customers (couples); incidental non-account attendees appearing in media
Capture sources *(added 2026-08-02 — closes DPO gate 0d)*	Three, and the RoPA previously named none of them explicitly: (1) **designated paparazzi seats** (a friend/family member claims a seat and shoots); (2) **the guests' OWN PHONES** — a guest buying or being granted Papic captures on their personal device, which is the dominant source now that Papic Pool sells as a shared-shot pool; (3) a **paired DSLR** bridged through a paired phone. Source (2) is the one this amendment exists to state: the media in this system is largely captured by ordinary attendees on their own handsets, not by an operator Setnayan or the couple controls. [+] **(4) Added 2026-10-22: a booked SUPPLIER's own phone** — see DPS-24
Personal data categories	Photos and video clips; likeness; capture metadata (`captured_at`, geo when available, device model, paired camera brand/model); tag associations
Delivery mechanism *(added 2026-08-02 — closes DPO gate 0d)*	Media is **sorted to a guest by face matching** where that guest consented to it (DPS-04), and delivered to their personal gallery. So a guest's likeness, captured on a *stranger's* phone, reaches them through an automated biometric match. The untagged-still-delivered rule means the couple receives everything regardless
SPI?	**N** in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI (health, religion). Treat as elevated
Recipients / sub-processors	Cloudflare R2 (originals, signed-URL only); Supabase (tags/metadata); hierarchical read: organizer / coordinator / guest (tagged + global) / vendor (booking-relevant)
Cross-border transfer	APAC (R2)

Retention	Full-resolution ORIGINAL: the later of 6 months from the event's first capture and 3 months after the event ENDS (the celebration's last day: `event_end_date` where the event spans several days, else `event_date` — owner 2026-08-10), then **replaced by** a compressed web copy. **Compressed web copy: free,** FOR LIFE **— owner 2026-08-18, *"we keep it for life"*, superseding the five-year window set on 2026-08-07, which had itself superseded the 2026-07-10 "free forever" lock.** There is no end date and no paid tier. **[X]** Nothing was ever deleted under any of the three rulings **— only the ORIGINAL's resolution ever changes. (!) The withdrawn paid option was never built and never priced, so this retires a PROMISE, not a product. This pack is unsigned and unfiled, so no superseded figure was ever declared to the Commission.** No scheduled deletion at any point. **No photo is ever deleted on a schedule.** Disposal occurs only on organizer removal, a validated erasure request, or account deletion. Originals synced to the couple's own Google Drive are theirs permanently and are never touched. Geo stripped on outbound shares; the original on R2 retains it (policy §4). (!) **CORRECTED 2026-08-07.** This row previously declared a **5-year hard limit** with 90-day-hot/5-year-cold tiering. That tiering was never built, no R2 lifecycle rule exists, and the compressed copy is kept indefinitely — so the row committed us, in a filing, to destroying photos we in fact keep. Declaring a purge that never happens is the more dangerous direction of drift: a commitment to the regulator broken every day.
Security measures	Signed URLs (5-min for sensitive media); no public reads; NSFW filter on-by-default (non-disableable); untagged-still-delivered; opt-out face-blur; couple review window before public unlock
Risk level	**Medium–High**

DPS-06 · Person Graph — Connections, Life Stories & Trusted-Circle (adults-only)

Field	Detail
Purpose	Durable person node; mutually-confirmed relationship connections; per-person life-story references; aggregate trusted-circle vendor signal (Person Graph pack)
Legal basis	Consent (§12(a)) — **mutual, opt-in confirmation** required for every edge; life stories rely on existing RSVP photo consent
Data subjects	Customers, guests (**adults only** — minors NOT processed)
Personal data categories	Person node (name, optional photo, events participated); first-degree connection edges (type + confirmed/pending state); life-story items = **references (pointers), not copies**; trusted-circle signal = **computed on read, not stored**
SPI?	**Potentially Y** — relationship data can infer SPI (e.g., civil status, family/religious ties). Mitigated: extended kin **derived not stored**; min-N ≥5 on aggregates

Recipients / sub-processors	Supabase (edges + references); no third-party sharing; connections never broadcast/browsable
Cross-border transfer	SG (Supabase)
Retention	Edges + references follow event/account retention (policy §4 / Compliance Pack §3); declined/hidden/opted-out suppressed immediately; reference dies with source media; trusted-circle not stored
Security measures	Mutual-confirmation gate; name-only + confirmed-only cross-person visibility; participant-scoped deny-by-default RLS; no "people you may know"; **no cross-event face recognition**; DPIA completed (Compliance Pack §2, residual Low)
Risk level	**Medium** — **Status: DRAFT, live behind flags; pending DPO/counsel sign-off.** Minors/legacy (Phase 3) counsel-first, DPIA scoped-not-complete, **not processed**

DPS-07 · In-App Communications / Chat (0019)

Field	Detail
Purpose	Text chat between couples ↔ vendors ↔ coordinators; document/sheet/PDF/image sharing on threads
Legal basis	Contract (§12(b)) — coordination is core service
Data subjects	Customers, vendors, coordinators
Personal data categories	Chat message content; attached files (doc/sheet/PDF/image); pasted external meeting links (plain text). Vendor identity masked (company logo, not personal photo)
SPI?	**N** structurally, but free-text/attachments may contain SPI — treat as elevated
Recipients / sub-processors	Supabase Realtime (ephemeral) + Postgres (history); Cloudflare R2 thread-files bucket. **Video meetings RETIRED 2026-05-16 — no video data stored**
Cross-border transfer	SG (Supabase); APAC (R2)
Retention	Messages: 5 years (aligned to event retention). Pasted meeting links follow parent message (policy §3.3, §4)
Security measures	RLS thread-scoping; per-thread coordinator join permission; vendor-identity masking; TLS 1.3; AES-256
Risk level	**Medium**

DPS-08 · Payments & Reconciliation (apply-then-pay)

Field	Detail

Purpose	Process PHP-direct service orders: BDO/GCash apply-then-pay to Setnayan's own accounts, reference codes, manual reconciliation of proof-of-payment against orders, and an AI read of the proof screenshot to check the reference the customer typed
Legal basis	Contract (§12(b)); **Legal obligation** (§12(c)) — PH tax/BIR record retention
Data subjects	Customers, vendors
Personal data categories	Payment receipts, transaction references, **partial** bank/e-wallet details for receipts/refunds; payment-proof screenshots; reconciliation inbox messages. **No complete card numbers, CVVs, or full bank account numbers stored**
SPI?	**N**
Recipients / sub-processors	Supabase (`payments`, `orders`, `receipts`, `payment_receipt_reads`); Cloudflare R2 (proof screenshot, private bucket); **Anthropic (US)** reads the screenshot to type out the reference and amount — it keeps the matched reference, amount, a match flag and one sentence, **not** the transcript, and it can never approve, reject or settle a payment (owner as DPO 2026-08-29, PR #4947, disclosed on `/privacy` §"Reading your payment receipt"); Setnayan Team (manual reconciliation). (!) CORRECTED 2026-10-22: no payment gateway is called — Maya and PayMongo are dormant in code (no API call). Apple in-app purchase: see DPS-23
Cross-border transfer	SG (Supabase); APAC (R2); US (Anthropic, receipt read)
Retention	Transaction/receipt records: **10 years** per the live `/privacy` schedule (BIR floor) — (!) corrected 2026-10-22 from "5 years"; earlier docs disagree, the public page governs. Pending orders expire 7 days (policy §4, CLAUDE.md)
Security measures	No card/full-account storage; two-admin approval for refunds >PHP 10K; append-only audit log; RLS; reference codes 8-char Crockford
Risk level	**Medium**

DPS-09 · In-App Activity Records & Admin Reporting (no product-analytics processor)

Field	Detail
Purpose	Operate the platform and report to Setnayan admins in aggregate: orders, bookings, inquiries and the per-page view counts suppliers, couples and storytellers see on their own pages
Legal basis	Legitimate interest (§12(f)) for aggregated operational reporting
Data subjects	Customers, vendors, guests

Personal data categories	The platform's own records (orders, inquiries, bookings, searches saved by the user) read in aggregate. Page-view counters for a supplier profile, storyteller chapter or Save-the-Date are kept with a one-way hash of a first-party cookie value only (`sn_vw`, `sn_vc`, `sn_vp`, `sv` on `/cookies`) so one browser is not counted twice. **Aggregated — never individually identified to admins outside dispute-mediation context**
SPI?	**N**
Recipients / sub-processors	Supabase (Postgres, Singapore) only. (!) **CORRECTED 2026-10-22 — PostHog is no longer a recipient.** The `posthog-js` dependency, its loader and the cookie-consent banner were removed in PR #6774 (merged 2026-10-22, *"essential cookies only — remove PostHog and the cookie banner"*). No third-party analytics service receives any data
Cross-border transfer	SG (Supabase)
Retention	Anonymized aggregate: indefinite (no PII). View-counter hashes: per the cookie lifetimes on `/cookies` (90 days to about 13 months). Underlying rows follow account/event retention
Security measures	Aggregation + de-identification for admin views; hashed counters only; admin-only RLS on reporting tables. (!) CORRECTED 2026-10-22 — the "opt-out toggle" previously listed here never existed (finding #13 of 2026-08-24); with PostHog gone there is no analytics stream to opt out of
Risk level	**Low**

DPS-10 · Email Notifications (Resend)

Field	Detail
Purpose	Transactional + milestone email: payment instructions/confirmation, refunds, vendor messages/status, RSVP received, wedding-day reminder, save-the-date, security alerts
Legal basis	Contract (§12(b)) for transactional mail; Consent (§12(a)) for promotional/marketing mail (revocable; RFC 8058 one-click unsubscribe)
Data subjects	Customers, vendors, guests
Personal data categories	Email address, recipient name, event/order context embedded in the message
SPI?	**N**
Recipients / sub-processors	Resend (delivery); browser push services for web-push notifications (when push keys are set). (!) Corrected 2026-10-22: no SendGrid fallback exists in code. **Guests receive no e-mail since 2026-09-29** (owner ruling) — notices to guests are in-app / QR / link only

Cross-border transfer	US (Resend)
Retention	Follows the underlying record; our own delivery log (`email_deliveries`) keeps a **masked** recipient, subject and outcome; provider-side log retention not verified
Security measures	TLS in transit; one-click unsubscribe; RA 10173 + CAN-SPAM compliant templates
Risk level	**Low**

DPS-11 · Public Site & Cookies (essential cookies only)

Field	Detail
Purpose	Run the public site (setnayan.com) and keep people signed in, carry guest passes and remember screen choices
Legal basis	Legitimate interest (§12(f)) / contract (§12(b)) for strictly necessary, first-party cookies. (!) **CORRECTED 2026-10-22 — the "consent for analytics/advertising cookies" basis is retired: there are no analytics or advertising cookies, so there is nothing to consent to and no banner** (`/cookies`, effective 2026-10-22)
Data subjects	Website visitors, account holders, guests
Personal data categories	First-party cookies only, each listed by name and lifetime on `/cookies`: the Supabase sign-in cookie (`sb-…-auth-token`), guest-pass cookies (`setnayan_guest_session`, `setnayan_guest_passes`), Terms-tick carriers, theme and screen-pairing choices, staff-only switches, and the view-count cookies of DPS-09. Browser storage: `sn_did` (fraud-protection random value — only its hash is stored, see DPS-12) and a Sentry masked-replay session key (DPS-26). Policy acceptance is logged with timestamp + IP + user-agent
SPI?	**N**
Recipients / sub-processors	Vercel (hosting); Supabase (sign-in). **No third-party cookies** — every cookie is first-party. Third-party display ads (AdSense) were retired 2026-05-19. The YouTube embed uses the privacy-enhanced player, which sets no tracking cookie until someone presses play
Cross-border transfer	US (Vercel hosting); SG (Supabase)
Retention	As printed per cookie on `/cookies` (5 minutes to about 13 months; the sign-in cookie up to 1 year). (!) CORRECTED 2026-10-22 — the "12-month consent-state persistence" previously referenced is retired with the banner
Security measures	First-party only; httpOnly sign-in cookie; TLS 1.3; HSTS; CSP; `essential-cookies-only.test.ts` guards the no-banner claim in the code
Risk level	**Low**

DPS-12 · Anti-Fraud & Trust Integrity (identity clustering · fraud scoring · enforcement)

Field	Detail
Purpose	Protect marketplace trust signals from manipulation: cluster likely-same-person/household accounts by shared strong signals; de-duplicate vendor review/rating/booking stats per cluster with arm's-length exclusion; score per-vendor fraud anomalies; two-stage enforcement (reversible auto-suspend + human four-eyes wipe/ban). Spec `03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md`
Legal basis	**Legitimate interest (§12(f))** — fraud prevention / marketplace integrity. **Requires** a documented legitimate-interest balancing + **disclosure** (both outstanding — DPIA R-08 §6). Automated-suspension effect engages §16(c) (right to object) + §34 (automated processing) `[TO CONFIRM]` counsel
Data subjects	Couples / guests (whose device/address/payment signals are clustered — **they never see cluster membership**) + vendors (scored, and subject to auto-suspend / ban)
Personal data categories	**Repurposed inputs (no new collection):** device fingerprint (`user_devices.device_hash`), normalized home address (`users.address_normalized`), payment-sender identity (`payments.reference_number`→paying user). **Derived:** identity `cluster_id`; per-vendor fraud signals + 0–100 scores with **non-PII** evidence (counts/ratios/opaque labels); enforcement state + append-only audit. **IP deliberately NOT captured**
SPI?	**N** — inputs are personal information, not §3(l) SPI. Elevated because it is **involuntary profiling with an automated decision that has a significant effect** (vendor livelihood)
Recipients / sub-processors	Supabase (Postgres, Singapore) only — no third-party/AI sub-processor. **Service-role / admin ONLY** (`REVOKE ALL FROM anon, authenticated` + `is_admin()` RLS at CREATE); Setnayan admins via `/admin/fraud` + two-admin approval gate
Cross-border transfer	SG (Supabase)
Retention	`identity_clusters` / `vendor_fraud_scores` = recomputed matviews (no history). `fraud_signals` + `fraud_enforcement_audit` persist — **explicit retention rule not yet defined `[TO CONFIRM]`**. Signal inputs follow their source systems (device/address = account retention; payment = 5-yr tax, DPS-08)
Security measures	Service-role/admin-only + deny-by-default RLS at CREATE; non-PII evidence; reversible auto-suspend at high threshold (score ≥90); **irreversible ban never automated** — four-eyes gate + typed confirmation; append-only audit; help-center appeal path; AES-256; TLS 1.3

Risk level	**High** — **Status: LIVE in production since 2026-07-07, ahead of counsel sign-off (owner-elected).** DPIA R-08 drafted (`08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md`); Privacy Policy Anti-Fraud disclosure + LIA + formal contest path outstanding

DPS-13 · Vendor AI Assistant — automated replies + business deep-search (0022)

Field	Detail
Purpose	The paid Vendor AI add-on, two capabilities: **(a) Auto-reply** — reads a couple's inbound messages + Event Brief (event date, guest count, budget-per-head, venue) in that couple↔vendor thread and drafts/auto-sends replies (and, if the vendor allows, accepts a booking) on the vendor's behalf, shown to the couple labelled " AI auto-reply"; **(b) Deep Search** — runs AI web-research over the **vendor's own** business across public sources (own website, directories, review sites) and stores a structured business dossier (`vendor_web_dossiers`) the vendor reviews to auto-fill its profile. Both are gated behind the `/admin/data-privacy` controls `vendor_ai_autoreply` + `vendor_deep_search` (fail-closed until DPO-activated)
Legal basis	**Contract (§12(b))** — the vendor's paid add-on operating on the vendor's own shop; **Consent (§12(a))** — the couple's own act of messaging that vendor grounds the auto-reply reading their thread. Auto-reply is **automated processing (§34)** with a standing " AI auto-reply" label and a §16(c) object path (every message still reaches the vendor). Deep Search of already-public third-party content relies on **legitimate interest (§12(f))**, minimised to a business summary with a 180-day retention limit `[TO CONFIRM]` counsel
Data subjects	Couples (inbound message text + Event Brief the auto-reply reads) + vendors (own business researched, dossier stored) + incidental third parties named on public web pages (Deep Search, e.g. a reviewer's public name)
Personal data categories	**Auto-reply:** couple inbound chat text + structured Event Brief fields (date, pax, budget band, venue) + the vendor's own package/pricing config; generated reply text. **Deep Search:** the vendor's own public business info (name, contact, services, review-derived facts) → `vendor_web_dossiers`. **Never** consumes SPI, face vectors, religion/faith, or the guest list
SPI?	**N** — no SPI; biometric, faith, and guest-PII consumption are explicitly carved out
Recipients / sub-processors	Supabase (Postgres, Singapore); **Anthropic web_search (US, Deep Search only)** — zero-retention API mode. **Single-tenant isolation**: a vendor's assistant reads only that vendor's own threads/business, never across vendors or across the couple's events
Cross-border transfer	SG (Supabase); **US (Anthropic — Deep Search only)**

Retention	Deep Search dossier `vendor_web_dossiers` — rolling **180-day** TTL `[TO CONFIRM]`. Auto-reply reads live thread + Event Brief data in place (no separate store beyond the chat system, DPS-07)
Security measures	Per-vendor single-tenant isolation; both capabilities **fail-closed** until DPO-activated on the `/admin/data-privacy` control board; " AI auto-reply" transparency label; SPI / face / guest-list carve-out enforced in code; TLS 1.3; AES-256
Risk level	**Medium** — automated processing (§34) of couple message content + AI web-research that may store incidental third-party PII. Public Privacy Policy §"Vendor AI assistant" + §"Vendor Deep Search" disclosures **LIVE**; the `/admin/data-privacy` controls hold both OFF until DPO sign-off; retention rule + LIA finalization outstanding

DPS-14 · Coordinator Delegated Access — consent scopes + prep-then-release (0021)

Field	Detail
Purpose	Let a couple delegate planning access to a **coordinator** they invite (a planner / family / friend — host-side, not Setnayan staff). At invite the coordinator accepts an RA 10173 **consent modal** scoping access to the couple's **guest list, seating, schedule, and vendor chats**. The couple may optionally grant **"Can finalize vendors"** and **"Can handle payments"** scopes (lock vendors + complete an apply-then-pay checkout on the couple's behalf). **Prep-then-release** lets the coordinator stage run-of-show/schedule blocks privately and release them to the couple (staged blocks hidden from couple/guests/vendors until released). Gated behind the `/admin/data-privacy` controls `coordinator_consent_money` + `coordinator_prep_release` (fail-closed)
Legal basis	**Consent (§12(a))** captured on the invite modal + **Contract (§12(b))** — service delivery. Money scopes are **opt-in by the couple**; consistent with the platform-wide rule that **Setnayan never HOLDS and never MOVES money** — settlement is direct couple↔vendor, off-platform, and the coordinator merely prepares the same off-platform payment. (!) **CORRECTED 2026-08-17 — the word “records” was struck: it was FALSE.** Setnayan DOES record couple→supplier payments the couple enters in their own budget — amount, date, method and reference number, with the supplier able to confirm receipt in-app. Measured in production 2026-08-17: **3 payment records totalling PHP 111,500** (2026-05-28 → 2026-06-05). Those records are declared at **DPS-20** below. The 0%-commission position is untouched: we never touch the money, we only write down that the couple says they paid it.
Data subjects	Couples (planning data + optional money authority delegated) + guests (whose PII the coordinator sees within scope) + coordinators

Personal data categories	Guest list + RSVP data, seating, schedule / run-of-show, vendor chat threads — scoped to the granted permissions; optional money-adjacent actions (vendor finalize, checkout) when the couple grants the scope; staged prep-release schedule blocks (hidden until released). **Face / biometric data excluded**
SPI?	**N** — no new SPI collection; scoped delegated access to the couple's existing planning data (incl. guest PII)
Recipients / sub-processors	Supabase (Postgres, Singapore) — RLS event/thread scoping + per-thread coordinator join permission (see DPS-07). **No new sub-processor**
Cross-border transfer	SG (Supabase)
Retention	Follows the parent event data (DPS-01 / DPS-03 / DPS-07) — life of the couple's account ((!) corrected 2026-10-22 from "5 years post-event", withdrawn 2026-08-17). Coordinator access is **revocable by the couple** at any time; revocation removes access prospectively
Security measures	RLS event/thread scoping; consent captured at invite (durable proof); money scopes opt-in **and** separately gated; face/biometric excluded; staged prep-release hidden until released; controls **fail-closed** until DPO-activated; TLS 1.3; AES-256
Risk level	**Medium** — widens a coordinator's access over guest PII and, if the couple grants it, money-adjacent actions. Public Privacy Policy §"Coordinators you invite" disclosure **LIVE**; confirm the DPO ruling before activating the `coordinator_consent_money` control

DPS-15 · Guest-Written Columns — guest-authored text published to the open web (2026-08-02)

Field	Detail
Purpose	Let a guest write one short column (title + body) for the couple's event page. After the couple approves it, the column is **published on the open web** on the public event page and may carry into the post-event editorial, under a byline drawn from the guest-list name
Legal basis	**Consent (§12(a))** — captured at submit time and stored as a durable timestamp (`consent_captured_at`, NOT NULL backstop); publication additionally requires the couple's approval. Withdrawal is self-serve and immediate
Data subjects	Guests (authors); persons named inside a guest's free text (incidental)
Personal data categories	Guest-authored free text (title ≤60 chars, body ≤280 chars) + the author's **byline** (their name as it appears on the event's guest list). No contact details are published

SPI?	**N by design, but elevated** — free text is unbounded in content and a guest may volunteer health, religious or political statements about themselves or others. Tier-1 automatic screening runs on every submit; treat as elevated
Recipients / sub-processors	**The open web** (public event page; post-event editorial). Supabase (Postgres, SG) for storage. **No new sub-processor**
Cross-border transfer	SG (Supabase); the published page is world-readable by nature
Retention	Lives with the guest record and the event. **Withdrawal by the author removes it from the page immediately**; deleting the guest record or the event removes it with them
Security measures	Two independent gates before any publication (automatic screening **and** couple approval — nothing auto-publishes); consent timestamp captured at submit so consent is never assumed; self-serve takedown (RA 10173 right to erasure/blocking); capability held **fail-closed** by the `/admin/data-privacy` control `guest_columns`
Risk level	**Medium** — publication of a named individual's words to the open web. Public Privacy Policy §"Guest-written columns on an event page" disclosure **LIVE** (scope, approval gate, byline, withdrawal, consent capture all stated)

DPS-16 · Papic Shared Pool — event-wide guest media visibility + self-linking (2026-08-02)

Field	Detail
Purpose	When the host opens the shared pool for their event, let **every signed-in guest of that same event** browse the event's whole capture pool, and let a guest **self-link** to a photo they appear in ("I'm in this"), which joins that photo to their personal gallery, ZIP download and Story reel
Legal basis	**Contract (§12(b))** — the capture/delivery service the couple bought; **Consent (§12(a))** — the guest's capture-time opt-in and the per-photo consent state; the host's per-event toggle (`events.pool_gallery_open`, default FALSE) is the additional gate
Data subjects	Guests whose likeness appears in the media; guests as viewers; incidental non-account attendees appearing in media
Personal data categories	**Compressed web copies only** of photos and short clips (never the geo-bearing original); `manual_pick` photo tags created by a guest self-linking
SPI?	**N** in the general case (images of persons are personal info, not per-se SPI), but images can incidentally reveal SPI. Treat as elevated — see DPS-05
Recipients / sub-processors	**Other signed-in guests of the SAME event only** — never the public, never anyone outside that event, never across events. Cloudflare R2 (web copies, signed-URL), Supabase (tags). **No new sub-processor**

Cross-border transfer	APAC (R2) + SG (Supabase) — unchanged from DPS-05
Retention	Follows DPS-05 — full-resolution ORIGINAL held the later of 6 months from the event's first capture and 3 months after the event ENDS, then **replaced by** a compressed web copy; the compressed copy is free, **for life** (owner 2026-08-18, *"we keep it for life"*, superseding the 2026-08-07 five-year window and its never-built paid option). [X] **No photo is ever deleted on a schedule — only its resolution changes. The host's toggle closes the pool retroactively** — turning it off withdraws event-wide visibility from media already captured. (!) **CORRECTED 2026-08-17.** This row was drafted 2026-08-02 and back-referenced DPS-05 as *"90 days hot + 5 years IA cold"* — the tiering that DPS-05 itself had already retired on 2026-08-07. It was never built, no R2 lifecycle rule exists, and it declared a destruction we do not perform.
Security measures	The pool read is a single RPC that bakes in **all three** protections: the FaceBlock blur rule, the consent-withdrawal rule ((!) updated 2026-10-22: since PR #4747/#4766 a withdrawn guest's face is **blurred and the photo kept**, no longer vetoed — owner ruling 2026-08-17), and **web-copy-only keys** so a geo-bearing original can never be served here; automatic screening must have passed; scoping is per-event and cannot drift; capability held **fail-closed** by the `/admin/data-privacy` control `papic_pool_gallery`
Risk level	**Medium–High** — this is the widening from *per-guest tagged delivery* to *event-wide visibility*: a guest's shots become visible to every other guest at that celebration. Public Privacy Policy §"Photos and videos — location data and guest capture" discloses the shared pool explicitly (scope, web-copies-only, screening, event-scoping, self-linking, and how to avoid it) — **LIVE**

DPS-17 · Same-Date Demand Signal — cross-couple aggregate (2026-08-02)

Field	Detail
Purpose	Tell a couple how many **other couples have inquired** with the same vendor for the **same exact date**, and feed that number to the "In demand right now" ranking lens as a sub-score
Legal basis	**Legitimate interest (§12(f))** — marketplace transparency so a couple can judge urgency on real activity rather than on a scarcity claim. Balancing test rests on the three minimisations below
Data subjects	Customers (couples) — both the couple who sees the number and the couples counted in it
Personal data categories	**An aggregate count only.** No identity, no event id, no vendor-couple pairing and no date of any other couple leaves the server — the recipient receives an integer
SPI?	**N**

Recipients / sub-processors	The inquiring couple, in-app only. **No new sub-processor**; the aggregation is a Postgres read
Cross-border transfer	SG (Supabase)
Retention	**None** — the count is computed per request and never stored
Security measures	Three minimisations, all server-side: (1) **inquiry-only** — the count discriminates on `chat_threads` existence, so a vendor a couple merely *saved* contributes zero (a save is not competition — owner ruling 2026-06-02); (2) **min-3 floor** — nothing below `MIN_DEMAND_COUPLE_COUNT = 3` is returned at all, because n=1 on a solo vendor for an exact date in a small municipality is functionally re-identifying; (3) **exact-date only**, with no month/year fallback, so a couple without a fixed date generates and receives nothing. Capability held **fail-closed** by the `/admin/data-privacy` control `same_date_demand` (seeded **inactive**)
Residual concern for the DPO	**There is no per-couple opt-out.** A couple cannot exclude their own inquiry from the counts other couples see. The mitigation is that what is disclosed is an aggregate at or above 3, never an identity — but the absence of an opt-out is the point on which a ruling is asked
Risk level	**Low–Medium** — the only cross-couple disclosure on the marketplace, but bounded to an integer ≥ 3. Public Privacy Policy §"Vendor interest counts (what other couples can see)" disclosure **LIVE**

DPS-18 · Live Video Connections — WebRTC signalling + TURN relay (2026-08-02)

Field	Detail
Purpose	Carry live audio/video **directly between two devices** for: voice/video calls inside a vendor conversation; a camera operator's phone feeding the couple's Live Studio control room; a guest tapping a side camera on an event page; and the homepage live demo. Relay the media through a TURN server **only** when a direct path is impossible
Legal basis	**Contract (§12(b))** — delivery of the calling / Live Studio features the user initiated
Data subjects	Couples, vendors, coordinators, guests, camera operators — anyone who joins a live connection
Personal data categories	**IP addresses**, as ICE candidates. A direct connection is only possible if each device learns the other's address; this is inherent to WebRTC everywhere, not something Setnayan adds. Plus a per-connection technical record of **whether the path was direct or relayed and the general network type**
SPI?	**N**

Recipients / sub-processors	The **other participant's device** (inherently receives the IP). **STUN** address discovery: Google or Cloudflare public servers. **TURN relay** (relayed sessions only). Setnayan's own infrastructure carries the setup messages **in transit**
Cross-border transfer	Yes — STUN/TURN endpoints are outside PH
Retention	**Addresses are not retained.** The candidate addresses pass through the signalling path in transit and are **not written to the database, not logged, and not used for anything else**. What is kept per connection is direct-vs-relayed + general network path type, for sizing relay cost — that record contains **no IP address and no audio or video**
Security measures	**Calls are never recorded** (platform lock). Media is end-to-end between the two devices on a direct path; on a relayed path the TURN server forwards encrypted media it cannot read. No content of any call is stored
Risk level	**Medium** — IP exposure between participants is unavoidable for the feature to exist and is disclosed in plain language rather than buried. Public Privacy Policy §"Live video connections (calls and event cameras)" explains the IP exchange, the STUN contact, the in-transit-only signalling, and exactly what is kept — **LIVE**. *(This entry closes the RoPA item owed for WebRTC/TURN — security handoff task #42.)*

DPS-19 · Coordinator Day-of Operations — filtered run-of-show · announcements · requests desk (2026-08-02)

Field	Detail
Purpose	The three surfaces a coordinator *acts* from on the event day, as distinct from the planning-phase delegation in DPS-14: (1) the **filtered run-of-show** — one master timeline auto-filtered per audience; (2) **day-of announcements** — a short broadcast to the event; (3) the **requests desk** — a single inbox of things raised on the floor
Why a separate entry	DPS-14 declares the coordinator's *consent scopes* and *prep-then-release*, i.e. what a coordinator may **see** and stage. It never named these three, and all three are **active in production**. Two of them are outward actions rather than reads — one of which reaches the couple's **guests** — so they belong on the register in their own right
Legal basis	**Contract (§12(b))** — running the event the couple engaged the platform for; **Consent (§12(a))** — the coordinator's own access consent captured at invite (DPS-14)
Data subjects	Couples; guests (as announcement recipients and as the subject of floor requests); vendors (as filtered-timeline recipients and requesters); coordinators
Personal data categories	**Run-of-show:** schedule blocks + responsible-party tags. **Announcements:** free text ≤500 chars + the sender's identity and timestamp; immutable once posted. **Requests desk:** the request's free text + who raised it + its lane/status

SPI?	**N** — no new sensitive category. Free text in an announcement or a request is unbounded in principle; both are event-scoped and short-lived
Recipients / sub-processors	**Announcements are read by everyone on the event** — couple, guests and vendors alike (RLS Pattern B member read + delegate read + admin observability). Run-of-show is *narrowed* per audience: a vendor sees only blocks they are tagged responsible on, a guest sees only public rows, the couple sees the master. Requests stay between the raiser and the coordinator/couple. Supabase (Postgres, SG). **No new sub-processor**
Cross-border transfer	SG (Supabase)
Retention	Follows the parent event — deleted with it (`ON DELETE CASCADE`). (!) Corrected 2026-08-17: this read "inside the 5-year event-data window"; that window is WITHDRAWN — event data is now kept for the life of the account (see DPS-01)
Security measures	All three held **fail-closed** by their own `/admin/data-privacy` controls (`coordinator_run_of_show`, `coordinator_day_of_broadcast`, `coordinator_requests_inbox`); event-scoped RLS with **canonical patterns only**; announcements are **immutable and attributed** — no silent edit or anonymous post; the run-of-show filter is a genuine **minimisation** (a vendor cannot read the parts of the day that are not theirs); **no acknowledgment tracking** was built, so reading an announcement is not recorded against a guest
Risk level	**Low–Medium** — the outward reach to guests is the notable part, and it is bounded to a short, attributed, event-scoped message. Public Privacy Policy §"Coordinators you invite (delegated access)" gained both missing paragraphs on 2026-08-02 (announcements + requests desk) — **LIVE**

DPS-20 · Couple→Supplier Payment Log — amounts the couple records against their own bookings (2026-08-17)

Field	Detail
Purpose	Let a couple keep their own record of what they have paid each supplier, against the payment milestones of a booking, and let the supplier confirm receipt. This is a LEDGER THE COUPLE WRITES — it is not a payment rail.
Why a separate entry	(!) **This activity was undeclared until 2026-08-17.** The register relied on a platform-wide sentence that Setnayan *"never holds, moves, or records the transfer of any money"*, and used it as the reason the coordinator's money scopes needed no financial-data declaration. **The "records" half was false**, so the only financial records that exist in the product were undeclared on the strength of it.

Legal basis	**Contract (§12(b))** — the budget/vendor-management service the couple engaged the platform for
Data subjects	Couples (organizers); suppliers (as payees); coordinators, where the couple has granted the money scope
Personal data categories	Amount in PHP, payment date, method (e.g. bank transfer, GCash), a free-text reference number, optional notes, an optional uploaded proof image, and the supplier + booking the payment is against. Plus who confirmed receipt and when
SPI?	**N** — financial information about a transaction the couple discloses themselves. No card numbers, no bank credentials and no account numbers are collected by the platform
Recipients / sub-processors	Supabase (Postgres, Singapore); Cloudflare R2 (Asia-Pacific) for an uploaded proof image. The supplier named on the row; a coordinator only where the couple granted the money scope
Cross-border transfer	SG (Supabase); APAC (R2, only where a proof image is uploaded)
Retention	Follows the parent event — life of the account (see DPS-01). (!) Financial records may attract the BIR/statutory floors of policy §4 where they evidence a taxable transaction; **the couple↔supplier settlement is off-platform and is not Setnayan revenue**, so the floor is not automatic. `[TO CONFIRM WITH COUNSEL]`
Security measures	RLS scoped to the event; the supplier sees only rows naming them; the coordinator's access is gated by the couple's opt-in money scope and the `coordinator_consent_money` control; proof images are signed-URL only
Risk level	**Low–Medium** — small volume, self-disclosed, no payment credentials. Measured in production 2026-08-17: **3 records totalling PHP 111,500** (2026-05-28 → 2026-06-05)
Note on the 0% commission position	Unchanged and still true: Setnayan **never holds and never moves** this money. The couple pays the supplier directly, off-platform. We record only what the couple tells us they paid

---

DPS-21 · First-party Site Visits — daily aggregates, daily-salted hash (added 2026-10-22)

Field	Detail
Purpose	Show Setnayan admins how many people visit which kinds of page, from where and on what device, without analytics cookies or a third-party analytics service (owner 2026-10-22: traffic stats *"belong in Admin › App Performance, not in Vercel; no cookies, no banner"*)
Legal basis	Legitimate interest (§12(f)) — operating and improving the site; balancing rests on the minimisations below
Data subjects	Every site visitor (signed in or not)

Personal data categories	**Processed for an instant, not stored:** the visitor's IP address and browser user-agent, combined into `sha256(IP | user-agent)` inside the request middleware. **Stored for one Manila day only:** that key hashed again with a random salt minted for the day (`site_visit_seen`, `site_visit_salts`). **Stored long-term, no personal data:** a daily aggregate row per route **pattern** (e.g. `/v/[slug]`, never a real address), referrer domain, `utm_source`, device class, two-letter country, signed-in yes/no, with view and visitor counts (`site_visit_days`)
SPI?	**N**
Recipients / sub-processors	Supabase (Singapore) only; Vercel provides the country header. **No cookie, no browser ID, no third party.** Admin-only read (`is_admin()` RLS) at `/admin/app-performance?tab=visits`
Cross-border transfer	SG (Supabase); US company (Vercel) in transit
Retention	Salt and salted hashes: **deleted by the first visit of the next Manila day**, after which two days' visitors can never be linked. Aggregates: kept (no personal data). Bots, admin pages, prefetches and previews are not counted
Security measures	Migration `20271282829207_site_visits_daily.sql` (PR #6771, merged 2026-10-22): RLS at CREATE; write only through a service-role function; CHECK constraints reject any path holding a 4+ digit run, a UUID, an `S89` id, `@`, `?` or `#`
Risk level	**Low.** (!) **Disclosure gap:** `/cookies` says *"beyond the view counts above, nothing measures how you use Setnayan"* and `/privacy` says *"No product analytics"* — neither mentions this cookie-less visit count. One sentence on both pages closes it (open copy item)

DPS-22 · Sign-in with Google and Apple (added 2026-10-22)

Field	Detail
Purpose	Let a person create or open their account with their Google or Apple account instead of a password, on the web and in the iPhone app
Legal basis	Contract (§12(b)) — account creation the user asks for; Consent (§12(a)) — the user's own choice of provider on the provider's consent screen
Data subjects	Account holders who choose Google or Apple
Personal data categories	From the provider: name, e-mail (for Apple possibly a **private-relay** address, stored as an ordinary e-mail), Google avatar URL — kept by Supabase Auth in the identity record. **Apple:** the user's Apple **refresh token**, sealed with AES-256-GCM in `apple_sign_in_tokens`, kept **only** so account erasure can revoke the Apple grant (App Store rule 5.1.1(v)); deleted at erasure. The iPhone sheet asks Apple for full name + e-mail

SPI?	**N**
Recipients / sub-processors	Google LLC / Apple Inc. (the identity provider — independent controllers of their own account data); Supabase Auth (Singapore)
Cross-border transfer	US (Google, Apple); SG (Supabase)
Retention	Life of the account. At erasure the Apple grant is revoked and its token row deleted. (!) **Known gap:** the Google/Apple name, e-mail and avatar copy in `auth.identities.identity_data` is **not** blanked by erasure today (DECISION_LOG 2026-10-22) — open engineering item
Security measures	Each provider is behind its own switch (`NEXT_PUBLIC_OAUTH_GOOGLE_ENABLED`, `NEXT_PUBLIC_OAUTH_APPLE_ENABLED`; code default off — **production values not readable from this session**); Facebook sign-in is hard-off in code; sealed Apple token, service-role only
Risk level	**Low.** (!) **Disclosure gap:** `/privacy` on `origin/main` does not describe sign-in with Google or Apple (only the sign-up line *"By continuing with Google or Apple, you agree…"*). A `/privacy#google-user-data` section is drafted on branch `rd/google-can-verify-setnayan` for Google's branding review — **not merged on 2026-10-22**

DPS-23 · Apple In-App Purchase (built, switched off — added 2026-10-22)

Field	Detail
Purpose	Let an iPhone-app user buy a digital add-on through Apple, as App Store rules require
Legal basis	Contract (§12(b)); Legal obligation (§12(c)) — the purchase is a financial record kept for BIR
Data subjects	Account holders buying in the iPhone app
Personal data categories	`app_store_purchases`: an app account token, user id, event id, product, Apple transaction ids, environment, price, currency, purchase / verification / revocation times, the last Apple notification type; each purchase also writes `orders` + `payments` rows. Apple's signed transactions are **verified offline** against Apple's pinned root certificate — **no outbound call to Apple**
SPI?	**N**
Recipients / sub-processors	Apple Inc. (the store — sees the purchase as its own transaction); Supabase (Singapore)
Cross-border transfer	US (Apple); SG (Supabase)

Retention	Kept as a financial record (10-year BIR floor); not removed by account erasure (`lib/erasure/coverage-guardrail.test.ts`)
Security measures	RLS on, no policy — service role only. **Switched off in code:** `NEXT_PUBLIC_APPLE_IAP_ENABLED` (default off) **and** a store-build user-agent check. The first App Store submission (iOS 1.0) went without in-app purchase (owner 2026-09-20)
Risk level	**Low** — and dormant until switched on. Not yet described on `/privacy` (to add before it is switched on)

DPS-24 · Supplier Papic Capture Lane, Supplier Copies & Guest Takedown (added 2026-10-22)

Field	Detail
Purpose	Let a supplier booked on an event (e.g. a caterer, stylist, photographer) take photos and short clips **of their own work** on their own phone, keep them as their own copy and portfolio, and let any guest pictured have a photo taken down — from the couple's gallery **and** from the supplier's own copy
Legal basis	Contract (§12(b)) — the supplier's booking; Consent (§12(a)) / legitimate interest (§12(f)) for the event's photo-consent model. Owner as DPO, 2026-09-16: a supplier's day-of photos are *"their own copy. they get to keep it for portfolio"*, and the guest is told *"before the first photo"*; on a takedown, *"we will honour the guest"*. Portfolio use after a 7-day guest notice (owner 2026-10-03)
Data subjects	Guests and couples appearing in supplier photos; suppliers
Personal data categories	`vendor_papic_captures`: supplier, event, R2 object key, photo or clip (≤10 s), device model, consent basis, NSFW check, hidden time. **No location stored.** `vendor_papic_portfolio_photos`: the supplier's imported portfolio album. Credit grants (`vendor_papic_capture_grants`, `vendor_papic_portfolio_credit_grants`)
SPI?	**N** in the general case; images may incidentally reveal SPI — treat as elevated (as DPS-05)
Recipients / sub-processors	Cloudflare R2 (APAC); Supabase (SG). The couple and event members see supplier captures only once NSFW-checked and not hidden. The supplier keeps its own copy
Cross-border transfer	APAC (R2); SG (Supabase)
Retention	Compresses like every other Papic photo (original replaced by the web copy, PR #4767); the supplier's camera closes on event day (PR #4971). **A takedown sets `hidden_at` on all four capture tables** — `papic_photos`, `papic_guest_captures`, `vendor_papic_captures`, `vendor_papic_portfolio_photos` (`lib/hide-a-reported-photo.ts`, held by `a-takedown-reaches-every-suppliers-copy.db.test.ts`); the supplier is told it came down, without the guest's name

Security measures	Insert only by a supplier booked on that event (RLS `current_vendor_booked_event_ids()`); NSFW screen on upload; gated by the `/admin/data-privacy` control `vendor_papic_capture` (seeded inactive; a code comment says active in production since 2026-07-16 — **not measured**). The capture count could not be re-measured (last reading 0 rows, 2026-09-22) — **no production access from this session**
Risk level	**Medium.** (!) **Two gaps:** (1) the takedown is **moderator-mediated** — a guest files a report and an admin hides it; (2) the guest's report button accepts only couple/guest photos, so **a guest cannot yet file a takedown against a supplier-held photo** — the machinery honours it, the entry point does not exist (DECISION_LOG 2026-09-16 / 10-02). Migration header still reads *"COUNSEL-GATED"*

DPS-25 · Text Checks — OpenAI moderation and LanguageTool (added 2026-10-22)

Field	Detail
Purpose	Screen text that will be published on an event page (the couple's story / editorial, guest-written columns) for abuse, and suggest spelling fixes
Legal basis	Legitimate interest (§12(f)) — keeping published pages safe; Contract (§12(b))
Data subjects	Couples (authors); guests (column authors); anyone named in the text
Personal data categories	The text itself, which may contain names and personal stories
SPI?	**N** by design; free text may volunteer SPI — treat as elevated
Recipients / sub-processors	**OpenAI (US)** — Moderation API, when its key is set; **LanguageTool (LanguageTooler GmbH, Germany)** — free public API, **always called** when an editorial is scanned, **no account and no DPA** (`apps/web/lib/editorial-scan.ts`)
Cross-border transfer	US (OpenAI); EU (LanguageTool)
Retention	Not stored by us beyond the text itself; provider-side retention not verified
Security measures	Text only, no account identifiers sent; both named on `/privacy`
Risk level	**Low–Medium.** Open owner decision since 2026-08-24: keep LanguageTool (no DPA) or drop the call

DPS-26 · Error Monitoring — Sentry (added 2026-10-22)

Field	Detail
Purpose	Find and fix software faults

Legal basis	Legitimate interest (§12(f)) — reliability and security
Data subjects	Any user whose request errors
Personal data categories	Stack traces, breadcrumbs, request context; on a **browser** error, a screen replay with **all text masked and all media blocked** (session sample 0, on-error sample 100%). The browser scrubs e-mails, phone numbers and keys named like e-mail / phone / token / password / address; the server scrubs face vectors and drops the event if scrubbing fails. `sendDefaultPii` is off
SPI?	**N**
Recipients / sub-processors	Sentry (US). Sets no cookies; the replay key lives in session storage
Cross-border transfer	US
Retention	Sentry's own retention; our `/privacy` promises error logs ≤ 90 days — (!) **no purge job found in code** for our own logs (open item)
Security measures	As above; runs only when the DSN is set
Risk level	**Low**

DPS-27 · Connected Accounts — YouTube (Live Watch), Google Drive, TikTok, Instagram; Gemini renders (added 2026-10-22)

Field	Detail
Purpose	Do what the user asks with an account they connect: run a Live Watch broadcast on YouTube; copy their event photos into their own Google Drive; post a Patiktok video to their TikTok; show a supplier's Instagram posts on their shop; render a paid mood board with Google's image model
Legal basis	Consent (§12(a)) — each connection is optional, off by default and asked for at the point of use; Contract (§12(b))
Data subjects	Couples, suppliers who connect an account; guests appearing in the media sent
Personal data categories	OAuth tokens (YouTube `youtube` scope; Drive `drive.file` only — Setnayan can touch only files it created; TikTok `user.info.basic`, `video.upload`, `video.publish`); broadcast details; the photos/videos sent; mood-board pictures sent to Gemini
SPI?	**N**
Recipients / sub-processors	Google LLC (YouTube, Drive, Gemini), TikTok, Meta (Instagram) — each under its own terms; Supabase holds the tokens
Cross-border transfer	US / SG

Retention	Until the user disconnects or deletes the account; keys erased on disconnect; files already written stay in the user's own Drive / channel. Google data deleted within 30 days of a request (`/privacy`)
Security measures	Google API Services User Data Policy incl. Limited Use, stated on `/privacy` and `/privacy/google-access`. (!) The Google and TikTok OAuth tokens are stored **unencrypted at the column level** (encrypted at rest by the database only) — a documented V1 posture with an encryption follow-up pending
Risk level	**Low–Medium**

DPS-28 · Pabuya — Gift Records on the Wish List (added 2026-10-22)

Field	Detail
Purpose	Let a couple show their gift-receiving details (GCash / Maya / bank handle or QR) and let a guest record that they sent a gift, so the couple can thank them
Legal basis	Consent (§12(a)) — the couple publishes their own handle; the guest chooses to record a gift; Contract (§12(b))
Data subjects	Couples; guests who record a gift
Personal data categories	The couple's e-wallet / bank handle and QR (`event_egift_methods`); per gift (`event_gift_records`, since 2026-10-08): the giver's name, amount in pesos, a message, an optional payment screenshot
SPI?	**N** — financial information the people disclose themselves; no credentials
Recipients / sub-processors	Supabase (SG); Cloudflare R2 (screenshot). Gift records visible only to the hosts and admins
Cross-border transfer	SG; APAC
Retention	Follows the parent event (life of the account)
Security measures	Host-only RLS; Setnayan never holds or moves the money
Risk level	**Low–Medium.** (!) **Disclosure gap:** `/privacy` §"Gift-receiving details (Pabuya)" says there is *no transaction ledger*; since 2026-10-08 gift records exist — the page should describe them (open copy item; NPC task `t1-5` already lists the e-gift disclosure)

---

2. Threshold analysis — mandatory NPC registration

Under **RA 10173 and NPC Circular 17-01** (as amended), a PIC/PIP must register its DPS and DPO with the NPC when **any** of the following triggers is met. Assessment below.

#	Registration trigger (Circular 17-01 §4 / related issuances)	Setnayan assessment	Met?
1	Processing **sensitive personal information of** ≥ **1,000 individuals**	Setnayan processes SPI: **biometric face vectors** (DPS-04), the **TIN on suppliers' BIR 2303** (DPS-02), **health/religious** data via dietary fields (DPS-03), religion / civil status / minors' details (dependents), and the marital status every wedding reveals. Last measured 2026-08-17: 48 data subjects, 0 face vectors — **not met today**; likely to be met at scale. (!) Corrected 2026-10-22 — "government ID + liveness" struck (retired 2026-07-03)	**Not yet — likely at scale**
2	PIC/PIP with ≥ **250 employees**	Sole proprietorship; headcount `[TO CONFIRM]` but almost certainly **< 250**	No (assumed)
3	Processing is **likely to pose a risk to the rights and freedoms** of data subjects	Yes — biometric processing, guest likeness/media captured on guests' and suppliers' phones, relationship graph, minors' details entered by parents, **and (DPS-12) involuntary identity-profiling with an automated decision that has a significant effect (auto-suspend/ban of a vendor's livelihood)**. This is high-risk processing by nature	**YES**
4	Processing is **not occasional** (i.e., regular/systematic core-business processing)	Yes — data processing is the platform's core, continuous business function, not incidental	**YES**

Conclusion. Registration triggers **#3 and #4 are met** (#1 not yet by count, likely at scale). Trigger #2 is not (sole prop, sub-250 headcount). Under Circular 17-01 the criteria are **disjunctive** — meeting even one obligates registration, and Setnayan meets at least two independently (risk-to-rights + not-occasional), with the SPI-volume trigger also likely once counts are confirmed.

> **Recommendation: Setnayan should register its DPO and Data Processing Systems with the National Privacy Commission** (NPC registration system), and appoint/confirm Indalecio Sacdalan Casasola II as the registered DPO. Registration is advisable on the risk-to-rights and not-occasional grounds alone; the SPI-volume trigger reinforces it. Confirm exact SPI data-subject counts `[TO CONFIRM]` and current NPC registration number `[TO CONFIRM]` before filing to determine whether this is an initial registration or an amendment.

3. Open items for DPO/counsel before filing

> Re-stated 2026-10-22. Filing is scheduled for **January 2027** (owner, 2026-07-30: *"we will do everything on january 2027 but let this run truthfully until then"*). The 15 tasks are tracked in `npc_filing_tasks` (`/admin/npc-readiness`); their current status lives in production and was not read from this session.

- `[OWNER TO SUPPLY]` Barangay + ZIP; BIR TIN (at filing, from admin → Compliance); DPO title; contact phone; adoption date.
- **Re-measure on filing day** the data-subject and SPI counts (`/admin/compliance/data-sheet`).
- **DPAs / SCCs:** none signed with any processor (task `t2-8`). Priority: Supabase, Vercel, Cloudflare, Resend, Sentry, Anthropic, OpenAI. Decide LanguageTool (no DPA possible on the free endpoint — keep or drop).
- **Public-page copy gaps** found 2026-10-22 (engineering PRs, not corpus): `/privacy` + `/cookies` do not mention the Visits count (DPS-21), sign-in with Google/Apple (DPS-22; the Google section is on an unmerged branch), Apple in-app purchase (DPS-23), the 12-hour face-selfie erase (DPS-04), Pabuya gift records (DPS-28), guest push notifications, breach notification, policy changes, portability or the right to complain to the NPC; `/privacy` still says "30–90 day tail" and `/terms` "30 days" for account deletion (no tail exists).
- **Product gaps:** no guest entry point to take down a supplier-held photo (DPS-24); `auth.identities` not blanked at erasure (DPS-22); no purge for support tickets (2 yrs), our error logs (90 days) or stale device records (24 months) that `/privacy` promises; no admin two-factor; no breach register in the product (task `t3-15`).
- DPS-06 (Person Graph) — minors/legacy (Phase 3) still need their own DPIA + NPC consultation before any build-to-live.
- DPS-13 / DPS-14 / DPS-15 / DPS-16 / DPS-17 / DPS-19 / DPS-24 are each held by an `/admin/data-privacy` control; a 2026-09-22 measurement read all 20 controls **active** — confirm on the board that each active control has the DPO ruling it needs.
- `same_date_demand` (DPS-17) — the per-couple opt-out ruling is still open.
- **Counsel:** external PH counsel review is task `t0-1` (recommended; owner's 2026-09-09 ruling is that it is not a gate to filing).

Draft compliance artifact prepared to a compliant baseline ahead of counsel. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel; this document is not a substitute for legal review and is not yet adopted for NPC filing.